

Article

Terminal-Assisted Web Authentication for Shared Devices with BLE-Based Confirmation Gating

Lingguang Lei ¹, Wentao Ma ², Qizhen Xu ^{1,*} , Guisen Li ¹  and Zhijie Zhang ¹ 

¹ School of Computer and Information Engineering, Xiamen University of Technology, Xiamen 361024, China; lglei@xmut.edu.cn (L.L.); lgs@xmut.edu.cn (G.L.); zjzhang@xmut.edu.cn (Z.Z.)

² Institute of Information Engineering, Chinese Academy of Sciences, Beijing 100085, China; mawentao2021@126.com

* Correspondence: qzxu@xmut.edu.cn

Abstract

In shared-device scenarios, terminal-assisted Web authentication reduces credential exposure by keeping authentication credentials on a user-carried mobile terminal. However, existing methods struggle to minimize mobile interaction while protecting against account misuse by other users of the shared device. This study proposes a session-bound, terminal-assisted Web authentication method that uses Bluetooth Low Energy (BLE) proximity evidence to adaptively tune user interaction. The method decouples identity verification from proximity-based interaction tuning: identity is verified via the mobile credential and digital signature, while proximity evidence based on the received signal strength indicator (RSSI) is used solely to determine whether explicit user confirmation on the mobile terminal can be omitted. It binds the credential, Web origin, session, proximity evidence, and selected action into a single signed transcript, restricting each response to its intended login. To handle sensing noise, an uncertainty-aware fallback policy allows the confirmation-free path only when proximity evidence is sufficient and the service policy permits it; weak or insufficient evidence requires explicit confirmation. We implemented an Android–browser–server prototype on commodity mobile terminals and shared devices without dedicated ranging hardware. In the evaluation, 93% and 82% of RSSI windows at 15 cm and 50 cm, respectively, were classified by the proximity gate as eligible for the confirmation-free path, whereas all windows at 100 cm or farther and in through-wall conditions required explicit confirmation. The measured prototype processing time averaged 1391 ms across 20 trials, excluding browser discovery, device selection, and user interaction. These results demonstrate prototype feasibility under the evaluated conditions.

Keywords: terminal-assisted authentication; Bluetooth Low Energy; proximity sensing; shared device; risk-adaptive authentication; Web security



Academic Editor: Aryya Gangopadhyay

Received: 14 August 2026

Revised: 12 September 2026

Accepted: 23 September 2026

Published: 25 September 2026

Copyright: © 2026 by the authors.

Licensee MDPI, Basel, Switzerland.

This article is an open access article distributed under the terms and conditions of the [Creative Commons Attribution \(CC BY\)](https://creativecommons.org/licenses/by/4.0/) license.

1. Introduction

Web systems are widely used in government services, offices, healthcare, and industrial operations. At integrated service counters, hospital workstations, and shop-floor maintenance terminals, one shared device is often used sequentially by multiple users: the device belongs to the organization, whereas the authentication credential should remain under the control of the current operator. Passwords on such devices are exposed to observation, reuse, phishing, and credential-stuffing risks [1,2]. Storing a long-term private key on a shared device similarly conflicts with the trust boundary between a personal

credential and a multi-user device. Terminal-assisted authentication offers a practical way to mitigate this conflict. Keeping personal authentication credentials and cryptographic operations on a user-carried mobile terminal prevents the shared device from persistently storing or directly processing reusable secrets, such as passwords and identity private keys, and provides a security carrier independent of the shared device for the current login.

Prior work on terminal-assisted authentication has mainly followed two lines. Explicit cross-device authentication uses domain-bound public-key credentials in WebAuthn/Passkeys and supports desktop-to-mobile authenticator invocation through Client to Authenticator Protocol (CTAP) hybrid transports [3–6]. QR-code login, one-time-password (OTP) mechanisms, and mobile-certificate protocols also move authentication operations to the mobile device [7–11], while QR-code phishing studies highlight risks in scanner-mediated workflows [12]. Behavior-based and continuous mobile authentication [13,14] can reduce repeated actions but addresses a different problem from session-specific cross-device authorization. Recent lightweight authentication and key-agreement schemes address related security and privacy problems in VANETs, AIoMT, V2G, and WBANs [15–18], but they do not target session-specific confirmation gating for managed Web login. Explicit cross-device approaches provide relatively clear authorization semantics but usually still require QR-code scanning, code entry, touch, or confirmation. Zero-interaction and co-presence authentications instead use short-range communication or environmental context, such as wireless and audio signals, to reduce repeated user actions [19–25]. However, communication reachability is not equivalent to physical proximity, and environmental co-presence generally indicates only that devices share a space. In a multi-user shared-device environment, such evidence cannot establish that the mobile terminal bound to the target account is near the current shared device, leaving an opportunity for another person in the same space to initiate a login and induce unintended use of the confirmation-free path. Relay effects and sensing errors further weaken such evidence.

This work investigates how to reduce mobile-terminal interaction during shared-device login while retaining authentication security and limiting unintended use of the confirmation-free path. We propose a session-bound Bluetooth Low Energy (BLE) proximity-risk gating method built around three coordinated mechanisms. First, identity authentication is separated from proximity-based interaction adjustment: the account-bound credential and signing operation remain on the mobile terminal to prove identity, while received signal strength indicator (RSSI) samples collected over a short BLE window provide only auxiliary risk evidence for deciding whether confirmation may be omitted. Because RSSI is sensitive to device and environmental conditions [26–28], it is neither treated as an identity credential nor interpreted as precise ranging. Second, the credential context, Web origin, current session, proximity evidence, and selected action are encoded in one canonical transcript and protected by a single signature, while the server atomically consumes the SessionID after successful verification. This unified session binding makes the response valid only for the designated account, Web origin, and current login session, thereby preventing credential replacement, cross-session reuse, and repeated or concurrent acceptance. Third, interaction adjustment follows a monotonic fallback rule: only sufficient proximity evidence under an allowed service policy enables the confirmation-free path; uncertain or weaker evidence requires explicit confirmation, whereas protocol, session, or authorization failures cause rejection.

The main contributions are as follows:

- A session-bound terminal-assisted authentication framework for shared devices is proposed. The mobile credential, current Web session, proximity evidence, and selected action are incorporated into one verifiable authentication transcript, enabling the server to verify both the intended use of the signature and its authorization tar-

get. The resulting security property is request-specific evidence-to-action integrity: a browser that relays the protocol cannot transplant the proximity evidence or alter the authorized interaction path across sessions without invalidating the signature.

- An uncertainty-aware gating method is introduced to adapt user interaction. The lower and upper bounds of a 1 s RSSI window, together with sample sufficiency, distinguish low-risk, uncertain, and high-risk evidence. Only sufficient low-risk evidence under an allowed service policy permits the confirmation-free path; uncertain, high-risk, or insufficient evidence requires explicit user confirmation.
- A prototype demonstrates deployment on commodity Android terminals and browser-equipped shared devices without dedicated ranging hardware, together with an integration path to an existing multi-channel certificate-based authentication standard. Under the evaluated conditions, 93% and 82% of windows at 15 and 50 cm, respectively, were classified by the proximity gate as eligible for the confirmation-free path, whereas all windows at 100 cm or farther and in the through-wall condition required explicit confirmation. The measured prototype processing time averaged 1391 ms across 20 trials, excluding browser discovery, device selection, and user interaction.

2. Related Work and Technical Background

2.1. Explicit Cross-Device and Terminal-Assisted Web Authentication

WebAuthn binds public-key credentials to a relying-party identifier and invokes authenticators through the browser; CTAP further defines USB, NFC, BLE, and hybrid transports that allow a desktop to use a mobile authenticator [3–6]. QR-code login, OTP mechanisms, and mobile-certificate protocols also move authentication operations to the mobile terminal [7–11], while QR-code phishing research highlights risks in scanner-mediated workflows [12]. Behavior-based and continuous mobile authentication [13,14] reduce repeated actions but are not equivalent to session-specific cross-device authorization. The explicit cross-device approaches can prevent a shared device from persistently storing or directly processing personal authentication secrets and provide explicit authorization semantics through user presence, user verification, or confirmation. Their common limitation is that they generally still require scanning, manual code entry, touch, or confirmation.

Beyond these Web-oriented methods, recent work in resource-constrained wireless networks addresses related authentication and privacy requirements. The vehicle-side lightweight conditional anonymous double-authentication (VLCADA) framework provides lightweight conditional-anonymous authentication with password robustness in VANETs [15]; FDAKES provides fully decentralized authentication and key exchange for AIoMT data sharing [16]; and a lightweight multifactor authentication and key-agreement scheme secures V2G communications [17]. For healthcare networks, fully anonymous broadcast signcryption supports secure one-to-many health data transmission in WBANs [18]. These schemes focus on authenticating wireless entities, establishing session keys, preserving anonymity, or protecting data dissemination within specialized network infrastructures. Our work instead protects interactive Web login on managed shared devices by binding the registered mobile credential, Web Origin, URI, SessionID, proximity evidence, and selected action in one signed transcript; BLE RSSI only determines whether explicit mobile confirmation may be omitted. The approaches, therefore, address different layers and are complementary rather than directly interchangeable.

2.2. Zero-Interaction and Co-Presence Authentication

Zero-Interaction Authentication (ZIA) maintains access through continuous communication between a user-carried token and a terminal and revokes access when the token leaves [19]. Jansen et al. used the discoverability, connectivity, and authentication status

of personal or organizational Bluetooth beacons to determine whether a mobile device was within communication range [20]. Such mechanisms impose little interaction, but connectivity only proves that devices are within radio range, not that they are at a specific physical distance, and radio range may be extended by relaying.

To improve co-presence reliability, Amigo, ProxiMate, and Sound-Proof use ambient wireless context, shared time-varying signals, and ambient audio, respectively [21–23]; multimodal fusion and its security properties have also been studied [24,25]. Nevertheless, environmental co-presence typically indicates only that two devices occupy the same or a similar environment. In offices, hospital work areas, and production control rooms, many users and their mobile devices can share similar wireless and acoustic contexts. Co-presence, therefore, does not establish that the target account's bound mobile terminal is near the particular shared device, nor does it prove that the credential holder is the person operating that shared device. The method proposed here uses finer-grained near-end proximity evidence to tighten the condition for the confirmation-free path.

2.3. BLE Proximity Evidence and Uncertainty Handling

BLE RSSI requires no dedicated ranging hardware, has low energy cost, and is widely supported by commodity devices; it is, therefore, used for indoor positioning, distance estimation, and wireless fingerprinting [26]. However, RSSI is sensitive to device model, holding posture, human-body obstruction, channel conditions, and multipath, making a single observation or fixed threshold an unreliable indicator of a unique physical distance [27]. Bluetooth 5.1 introduced direction finding using the Constant Tone Extension (CTE) and I/Q sampling, enabling Angle of Arrival (AoA) or Angle of Departure (AoD) techniques for more accurate positioning. Commodity Android terminals and laptops, however, generally do not expose such capabilities without dedicated anchors, antenna arrays, or development hardware [29,30].

Wireless-feature-based authentication and proximity detection have, therefore, explored complementary approaches. LocAuth uses environmental fingerprints and supervised learning to recognize trusted indoor areas [31]. Filus et al. combine RSSI changes, inertial measurements, and machine learning to filter unreliable proximity detections [28]. Other studies improve localization using real-time calibration, triangulation, ranking, or fingerprint augmentation [32–37]. Related Wi-Fi localization studies further mitigate the impact of RSSI variability on localization through fingerprint feature vectors [38] and improve indoor positioning accuracy through weighted centroid optimization [39]. These studies mainly target trusted-area recognition, filtering, or localization accuracy. In contrast, our approach uses the built-in BLE capabilities of commodity Android terminals and laptops, treats a short RSSI window as auxiliary risk evidence, and integrates evidence classification, interaction adjustment, and Web-session protection into a complete authentication workflow.

Existing proximity and co-presence approaches mainly use BLE/RSSI or ambient context to establish nearby-device presence or authorize access [3–6,19–25]. Our method instead uses an experimentally evaluated near-end RSSI boundary to adapt the mobile-confirmation requirement for each shared-device Web login and binds the resulting evidence and action to that authentication session, preventing cross-request reuse while retaining credential-based identity authentication. WebAuthn/CTAP provides standardized credential-based cross-device authentication with explicit user-presence or user-verification semantics; our method does not replace that credential layer but adds a session-bound proximity gate that adapts the confirmation policy for the target managed shared-device setting.

2.4. GB/T 40018-2021 Multi-Channel Certificate Protocol

GB/T 40018-2021 [11] specifies a multi-channel protocol for certificate requests and certificate-based applications using smart mobile devices. In its digital-signature authentication procedure, the service system creates a request containing a URI, random value (RND), session identifier (SessionID), system description, and extension fields. The mobile device obtains and signs the request, after which the service system verifies the signature and completes authentication, as illustrated in Figure 1.

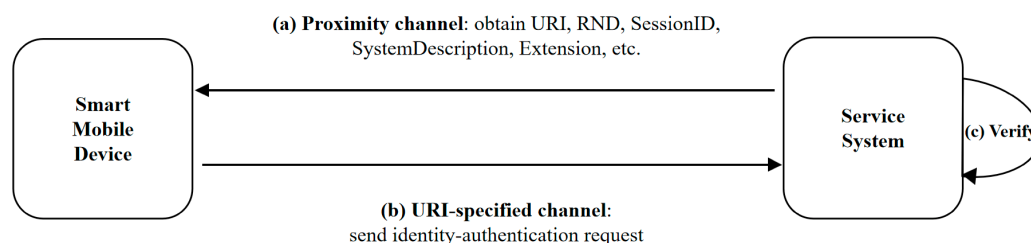


Figure 1. Digital-signature authentication procedure in the multi-channel certificate protocol.

The standard provides a challenge–response structure, basic fields, and a cryptographic implementation basis for mobile certificate use, but it does not define what proximity evidence is sufficient to omit confirmation. It also does not address same-space misuse, binding of proximity evidence and the selected action to the Web origin, or one-time atomic consumption of SessionID. Our method reuses URI, RND, SessionID, and extension fields while adding near-end proximity-risk gating, confirmation fallback, and session binding. SM2 and GB/T 40018-2021 are prototype instantiation choices rather than prerequisites for the general method.

3. System Model and Design Goals

3.1. Application Scenario

The method targets browser-equipped shared devices that are used sequentially by multiple users to access Web services and are unsuitable for long-term local storage of personal passwords, certificates, or private keys. The personal authentication credential and signing private key remain on a user-carried mobile terminal, while the shared device supports BLE and relies on the mobile terminal to assist authentication of the current Web session. Comparable deployment constraints already exist in practice. NHS Care Identity Service, for example, allows healthcare staff to share desktop or laptop computers while using personal smartcards to access clinical systems [40]. One-window government-service counters integrate services from multiple departments on fixed service terminals [41], and Microsoft lists libraries, schools and university laboratories, and shared office workstations as typical shared-device deployment scenarios [42]. The shared device is also assumed to run a browser that exposes the Web Bluetooth interface used for BLE message transport [43].

3.2. Threat Model

We assume that the authentication server and its certificate validation logic are trusted, the HTTPS channel is not compromised, and the identity private key on the mobile terminal is non-exportable. As described in Section 3.1, the intended shared-device scenarios are generally managed environments rather than fully open ones. In these environments, the attacker is assumed to be an ordinary user of the shared device who can use the browser to access authorized Web services, initiate authentication while the victim’s mobile terminal keeps Bluetooth and the authentication service available, and copy or replay application-layer messages exposed to the browser. Ordinary-user privileges do not allow the attacker to install native software on the shared device, obtain operating-system administrator

privileges, modify the system or Bluetooth stack and settings, or control the shared device's radio hardware. The attacker also cannot control the mobile authentication application or obtain its private key. We further assume that, in the managed deployment environment, routine physical supervision makes it difficult for an attacker to operate additional relay equipment or directional antennas near the shared device without detection. These conditions are deployment assumptions consistent with the intended scenarios, rather than security guarantees provided by the protocol itself.

Based on these deployment assumptions, the threat model does not consider relay and related active proximity-manipulation attacks, including BLE relays, transmit-power manipulation, directional antennas, and close-range proxies. Such attacks generally require additional radio equipment, software or configuration privileges beyond the ordinary browser access considered here, or an additional device near the mobile terminal. Authenticated and encrypted access for bonded BLE devices [44] can restrict unauthorized BLE endpoints, while prior BLE and physical-layer relay studies [45,46] motivate the use of independent evidence. Complementary mechanisms include acoustic co-presence verification [47], distance-bounding protocols [48], and Bluetooth Channel Sounding [49]. Section 5.4 analyzes how these deployment assumptions and dedicated mechanisms can limit or counter the corresponding attack capabilities.

3.3. Design Goals

The design goals are as follows:

- Protection of personal authentication secrets. The shared device must not persistently store or directly process reusable secrets such as passwords or identity private keys, and multi-user operation must not expose the private key held by the mobile terminal.
- Authentication-use restriction. Each result must be valid only for the designated service account, target system, and current login process, and must not be replaceable, transferable to another service or session, or accepted multiple times through repeated or concurrent submission.
- Low-interaction authentication. When the mobile terminal is near the shared device, the authentication conditions are trustworthy, and the service policy permits it, manual actions on the mobile terminal should be omitted where possible. Insufficient or higher-risk evidence must fall back to explicit confirmation, and weaker evidence must never provide confirmation-free-path eligibility.
- Deployability and adaptability. The shared-device side should avoid dedicated client software or browser plug-ins where possible, reducing integration cost for existing Web systems while preserving an integration path with existing cryptographic infrastructures and standards.

3.4. Key Challenges and Authentication Semantics

The action state specifies how the trusted mobile application may invoke the terminal-protected private key for the current request. AUTO denotes the confirmation-free path: when the policy conditions are satisfied, the mobile application proceeds without per-request user confirmation and signs the session-bound response. CONFIRM permits the same signing operation only after explicit local confirmation, and REJECT produces no signature. AUTO and CONFIRM, therefore, differ in user-intent evidence and interaction, not in the server-side identity-authentication result; both successful paths require the same credential, signature, and session verification. Three challenges arise. First, the credential, Web session, proximity evidence, and selected action are generated by different components and must be bound to a unified authentication transcript to prevent replacement, redirection, or replay. Second, RSSI depends on the device and environment and only a short

observation window is available; the system must, therefore, decide whether the request is eligible for the confirmation-free path without treating it as precise ranging. Third, because AUTO lacks an explicit per-request user-authorization signal, weaker evidence must never authorize automatic signing.

To address these challenges, the method defines three semantics: session/evidence binding, proximity-evidence classification, and action authorization. Proximity evidence is classified as low-risk L, uncertain U, or high-risk H according to sample sufficiency and the RSSI-window bounds. $\text{Crypto}_{\text{OK}}$ denotes valid credentials and signature; $\text{Session}_{\text{OK}}$ denotes a response corresponding to the current login and not previously accepted; $\text{EvidenceBind}_{\text{OK}}$ denotes that the proximity evidence and selected action are jointly protected with the current request; and $\text{ActionAuth}_{\text{OK}}$ denotes that the selected action satisfies its authorization condition. Auto_{OK} holds when the action is AUTO, the evidence is low risk, and the service policy permits use of the confirmation-free path. $\text{Confirm}_{\text{OK}}$ holds when the action is CONFIRM and the user has explicitly confirmed. The acceptance semantics are defined as follows:

$$\text{Crypto}_{\text{OK}} = \text{Cert}_{\text{OK}} \wedge \text{Bind}_{\text{OK}} \wedge \text{Sig}_{\text{OK}} \quad (1)$$

$$\text{Session}_{\text{OK}} = \text{Fresh}(\text{SID}) \wedge \text{Match}(\text{C}, \text{WebSession}) \quad (2)$$

$$\text{ActionAuth}_{\text{OK}} = \text{Auto}_{\text{OK}} \vee \text{Confirm}_{\text{OK}} \quad (3)$$

$$\text{Accept} = \text{Crypto}_{\text{OK}} \wedge \text{Session}_{\text{OK}} \wedge \text{EvidenceBind}_{\text{OK}} \wedge \text{ActionAuth}_{\text{OK}} \quad (4)$$

All four conditions are required. AUTO is authorized only with low-risk proximity evidence under an allowed service policy, whereas CONFIRM uses explicit user confirmation as the authorization basis. REJECT never satisfies the acceptance condition. RSSI participates only in deciding whether the request is eligible for the confirmation-free path; it does not prove identity or infer an exact physical distance. The server ultimately verifies consistency among the credential, current login process, proximity evidence, and selected action.

4. Terminal-Assisted Web Authentication Method

4.1. Overall Architecture

The overall design follows layered decision making with unified signature binding. A credential-verification layer uses the non-exportable identity private key on the mobile terminal to prove credential possession. A session-binding layer lets the authentication server generate the challenge and maintain Origin, URI, and SessionID, thereby defining which Web request is being signed. A risk decision layer on the mobile terminal combines proximity evidence with the service policy to decide whether user confirmation can be omitted for this authentication. Critical fields from all three layers are encoded in one canonical structure and signed together, allowing the server to jointly verify credential possession, session use, and the selected action.

As shown in Figure 2, the system consists of a mobile authentication application, a shared-device browser component, and an authentication server. The mobile application manages the credential and private key, BLE communication, proximity-risk classification, and digital signatures. On the shared device, the browser component is implemented as JavaScript delivered with the service Web page and, therefore, requires no separately installed client software or browser plug-in. The browser-side script requests the challenge, invokes Web Bluetooth under the browser permission model, and relays authentication messages, while the operating system and Bluetooth stack provide the underlying BLE communication support. The server performs account binding, challenge and session

management, signed-transcript reconstruction, signature verification, and SessionID consumption. The shared-device component neither stores nor directly processes personal authentication secrets and cannot independently determine authentication success. The general method does not depend on SM2-specific operations; it requires only an unforgeable digital signature with a private key protected by the mobile terminal.

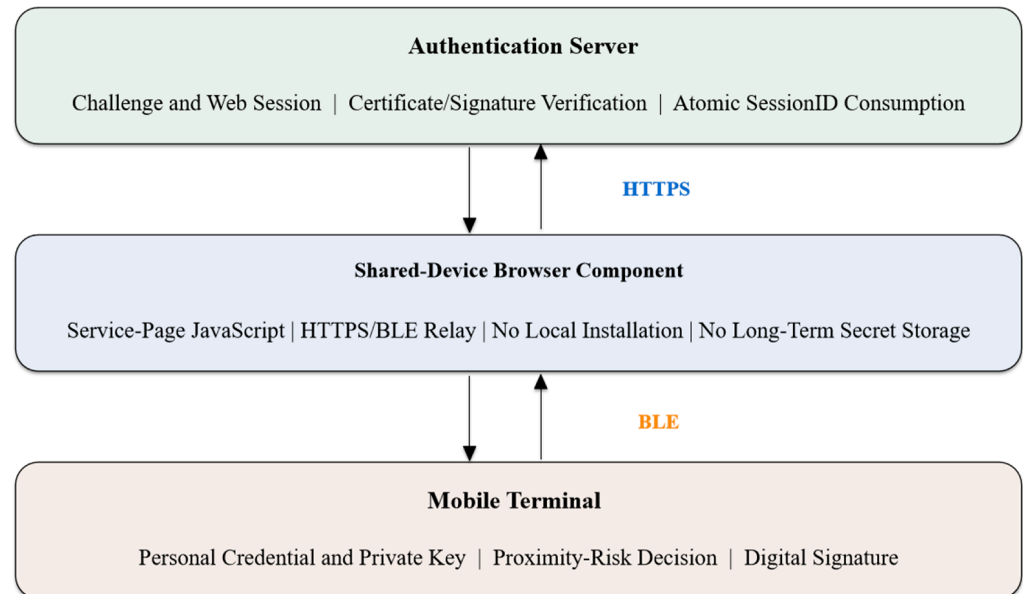


Figure 2. Overall system architecture.

During authentication, the browser relays the challenge and response between the shared device and mobile terminal through Web Bluetooth. The mobile application selects AUTO or CONFIRM based on Android-side RSSI proximity evidence and service policy; protocol, session, or authorization-check failures lead to REJECT. BLE is used only as a near-field message channel and a source of risk evidence for interaction adjustment. Identity authentication itself is completed through mobile-terminal signing, server-side verification, and session consumption.

4.2. Credential Binding and Challenge–Response Authentication

During initial binding, the server first completes the existing account-verification procedure and generates a one-time binding nonce N_B . It associates N_B with Origin, AccountID, the candidate certificate identifier CertID, and expiration time $t_{exp,B}$. The mobile authentication application constructs $T_B = \text{Encode}(\text{"TAWA-Bind-v2"}, \text{Origin}, \text{AccountID}, \text{CertID}, N_B, t_{exp,B})$, signs it with the private key corresponding to the candidate certificate to obtain σ_B , and returns $(\text{CertID}, \sigma_B)$. The server reconstructs T_B , verifies the certificate chain and σ_B , atomically consumes N_B , and then establishes the AccountID–CertID binding. N_B , T_B , and σ_B , thus, denote the one-time binding challenge, binding transcript, and binding signature, respectively.

After credential binding, the authentication server creates challenge C for the current Web login. After observing the RSSI window, the mobile application constructs proximity evidence E_k and signs its digest and selected action Action_k together with the challenge. The signature, therefore, states not only whether the private key is possessed but also which session is approved, which window evidence was used, and which interaction strength was selected. To prevent cross-protocol and cross-service reuse, Tag, Origin, URI, SessionID, the random value, and CertID are included in deterministic encoding. SID denotes SessionID,

t_{exp} denotes the challenge expiration time, and Ext denotes the extension-field set used for protocol adaptation. The abstract message forms are:

$$C = (\text{RND}, \text{SID}, \text{Origin}, \text{URI}, \text{CertID}, t_{\text{exp}}, \text{Ext}) \quad (5)$$

$$E_k = (\text{SID}, t_k, n_k, \mu_k, l_k, u_k, \Delta_k, z_k, \text{PolicyID}) \quad (6)$$

$$T_A = \text{Encode}(\text{Tag}, C, H(E_k), \text{Action}_k) \quad (7)$$

$$\sigma = \text{Sign}_{s_k}(T_A) \quad (8)$$

$$A = (\text{CertID}, E_k, \text{Action}_k, \sigma) \quad (9)$$

Tag is set to “TAWA-v2” to separate this protocol domain from a signing protocol that does not include proximity evidence. E_k contains the observation time, sample count, window statistics, risk region, and policy identifier. H is a cryptographic hash function matched to the signature security level, and $H(E_k)$ abbreviates $H(\text{Encode}(E_k))$. C , E_k , and T_A use deterministic encoding under the Distinguished Encoding Rules (DER). Origin is encoded as a scheme–host–port tuple, URI uses the server-normalized service path, and CertID uses the unique identifier registered by the server. Equation (9) defines response A ; A is generated once by the mobile application after the authorization condition for AUTO or CONFIRM is satisfied and is then relayed unchanged by the browser over BLE and HTTPS. The browser does not reconstruct or modify A . The server reconstructs C from protected session state, recomputes $H(E_k)$, verifies σ and checks whether Action_k satisfies the policy. Origin, URI, or SessionID values returned by the browser are not treated as trusted inputs. In the prototype, the generic Sign operation is instantiated with SM2. Because the reported RSSI still depends on the trusted mobile application and terminal assumptions, evidence binding prevents replacement and cross-session reuse but does not prove that the measurement cannot be forged.

Figure 3 summarizes the authentication process, which extends the conventional challenge–response procedure with proximity-evidence construction and signature binding. In Figure 3, GATT denotes the BLE Generic Attribute Profile used for the forward and reverse connections.

The process proceeds as follows:

1. At the login page, the user initiates terminal-assisted authentication, and the browser requests a challenge from the authentication server.
2. The authentication server creates a one-time RND and SessionID; binds them to the requested URI, creation time, certificate identifier, and browser Web session; and returns $C = (\text{RND}, \text{SID}, \text{Origin}, \text{URI}, \text{CertID}, t_{\text{exp}}, \text{Ext})$ to the browser.
3. The browser invokes the Web Bluetooth API when necessary, obtains device permission, connects to the selected mobile terminal, and relays challenge C to the mobile terminal over BLE. The mobile authentication application performs a preliminary check on the received challenge, including its format, Origin, RND, SessionID, URI, CertID, encoding uniqueness, and expiration time. This pre-check only filters malformed or stale challenges and determines whether processing should continue; it does not constitute final authentication verification. A fixed protocol Tag is used later in the signing step. Any failed pre-check terminates processing before RSSI measurement or signing.
4. After the preliminary challenge check, the mobile application obtains the peer shared-device RSSI through the reverse BLE connection described in Section 4.3. Within the configured 1 s window, it computes the mean, lower and upper bounds, range, and sample count and applies the three-region rule to obtain z_k . If the reverse path is

- unavailable, RSSI reading fails, or the sample count is insufficient, the evidence is marked insufficient and the process enters CONFIRM.
- The mobile application combines service sensitivity and z_k to determine $Action_k$ and constructs E_k and T_A . If $Action_k$ is CONFIRM, the user must explicitly confirm after local unlock or verification before signing. Once the authorization condition for AUTO or CONFIRM is satisfied, the mobile application computes $\sigma = \text{Sign}_{sk}(T_A)$ and forms the unique response $A = (\text{CertID}, E_k, \text{Action}_k, \sigma)$.
 - The mobile application returns the already-formed response A to the browser over BLE. The browser relays the same A unchanged to the server over HTTPS. The server then performs the final authentication verification: it reconstructs C and T_A , recomputes $H(E_k)$, verifies the certificate chain, account binding, signature σ , session lifetime, policy identifier, proximity-evidence binding, and $Action_k$, and atomically changes SessionID from ISSUED to USED using a compare-and-swap or equivalent transaction, so that one authentication response can be accepted at most once.
 - Only after signature, session, evidence-binding, and action-policy checks all succeed does the server establish a Web session for the bound account. Any failed check causes rejection and is recorded.

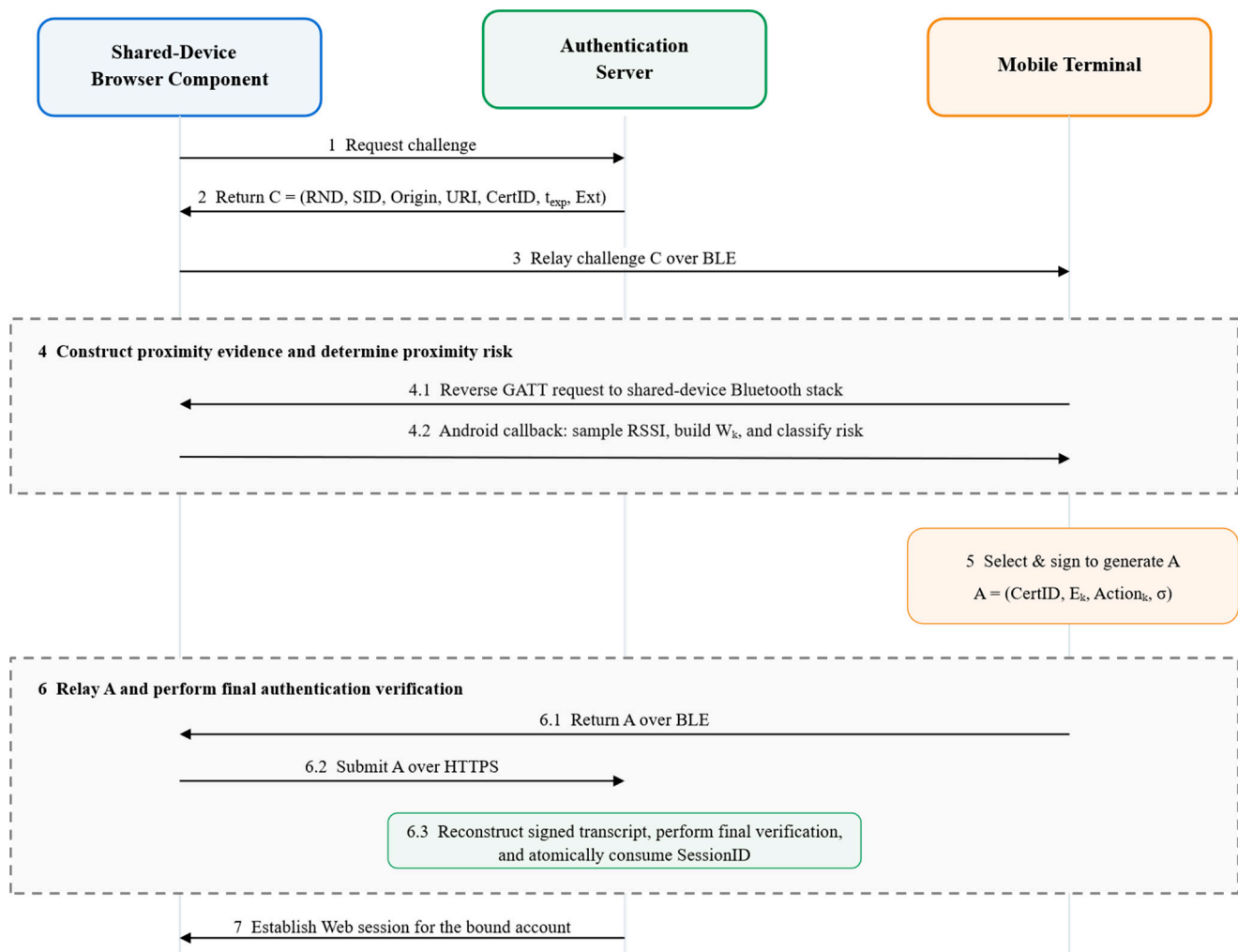


Figure 3. Terminal-assisted Web authentication process.

4.3. BLE Channels and Protocol Mapping

BLE interaction has two logical paths: message transport and RSSI acquisition. For message transport, the mobile authentication application exposes the authentication service

as a Peripheral/GATT Server. The browser filters devices by service UUID, acts as a Central/GATT Client, sends C through the challenge characteristic, and receives authentication response $A = (\text{CertID}, E_k, \text{Action}_k, \sigma)$ through the response characteristic. The browser relays this same A unchanged to the server over HTTPS; it neither reconstructs nor modifies the response. After authentication, timeout, or disconnection, the mobile application clears window samples and short-lived session state so that proximity evidence cannot be reused for another challenge.

In this method, Web Bluetooth is only a browser-permission-controlled interface for BLE message transport; it is neither the identity trust root nor the RSSI acquisition interface. The browser-side component relies on the Web Bluetooth GATT-client interface provided by Chromium-based browsers. As described in Section 4.1, it is delivered with the service Web page as JavaScript, so no dedicated software or browser extension is required on the shared device. The browser acts as a Central/GATT Client connected to the mobile GATT Server, and first-time discovery requires manual device authorization in the browser [43].

After the browser-to-mobile GATT connection is established, `BluetoothGattServerCallback.onConnectionStateChange()` supplies the Android application with the peer shared-device `BluetoothDevice` object. The application then calls `device.connectGatt()` for that peer and requests peer-link RSSI through `readRemoteRssi()`, with successful samples returned through `BluetoothGattCallback.onReadRemoteRssi()`. No application-defined GATT service is configured on the laptop for this step, and Web Bluetooth does not create a laptop-side GATT Server. The term reverse GATT path denotes this Android-side GATT-client handle, which depends on the shared device's native Bluetooth stack, adapter, and driver accepting the connection. If the connection or RSSI callback is unavailable, or fewer than $n_{\min}$ samples are collected, the evidence is insufficient and the policy requires CONFIRM; AUTO is not permitted.

4.4. RSSI-Based Proximity-Risk Decision

The method constructs proximity-risk evidence from the peer shared-device RSSI obtained on the mobile terminal and does not require dedicated ranging hardware. The prototype uses a 1 s observation window as a trade-off between authentication latency and short-term evidence sufficiency. This duration is an experimental parameter rather than a universally optimal value. The purpose of RSSI is not to estimate an exact distance or assume that shorter distance always implies lower variance; instead, it tests whether all available observations in a short window consistently support a low-interaction authentication decision.

Figure 4 shows the risk decision chain after a preliminary challenge pre-check. The pre-check only filters malformed, mismatched, or stale challenges; it is not the final authentication verification. After the pre-check, the mobile terminal constructs the RSSI window, classifies proximity evidence, and selects AUTO or CONFIRM according to evidence strength and service sensitivity. The low-risk region can support AUTO only when the service is ordinary and the sample count is sufficient. The uncertain and high-risk regions and high-sensitivity services require explicit confirmation. Pre-check failure, user rejection, or confirmation timeout enters REJECT. After signing, the server performs the final authentication verification described in Section 4.2; any final verification failure also causes REJECT.

Service sensitivity is configured manually by the service provider and enforced uniformly by the authentication server. Classification is based on the consequence of using the confirmation-free path. Services or protected URIs that expose non-public personal, medical, financial, account-security, or administrative data, or permit privileged or state-changing operations, are classified as high sensitivity; logging in to them always requires

CONFIRM. Only services or protected URIs explicitly allowed listed as ordinary, such as public-document libraries, campus-announcement portals, and exhibition-guide portals that provide public content and low-impact functions, may be eligible for AUTO. Unclassified services default to CONFIRM. AUTO additionally requires sufficient samples and low-risk proximity evidence.

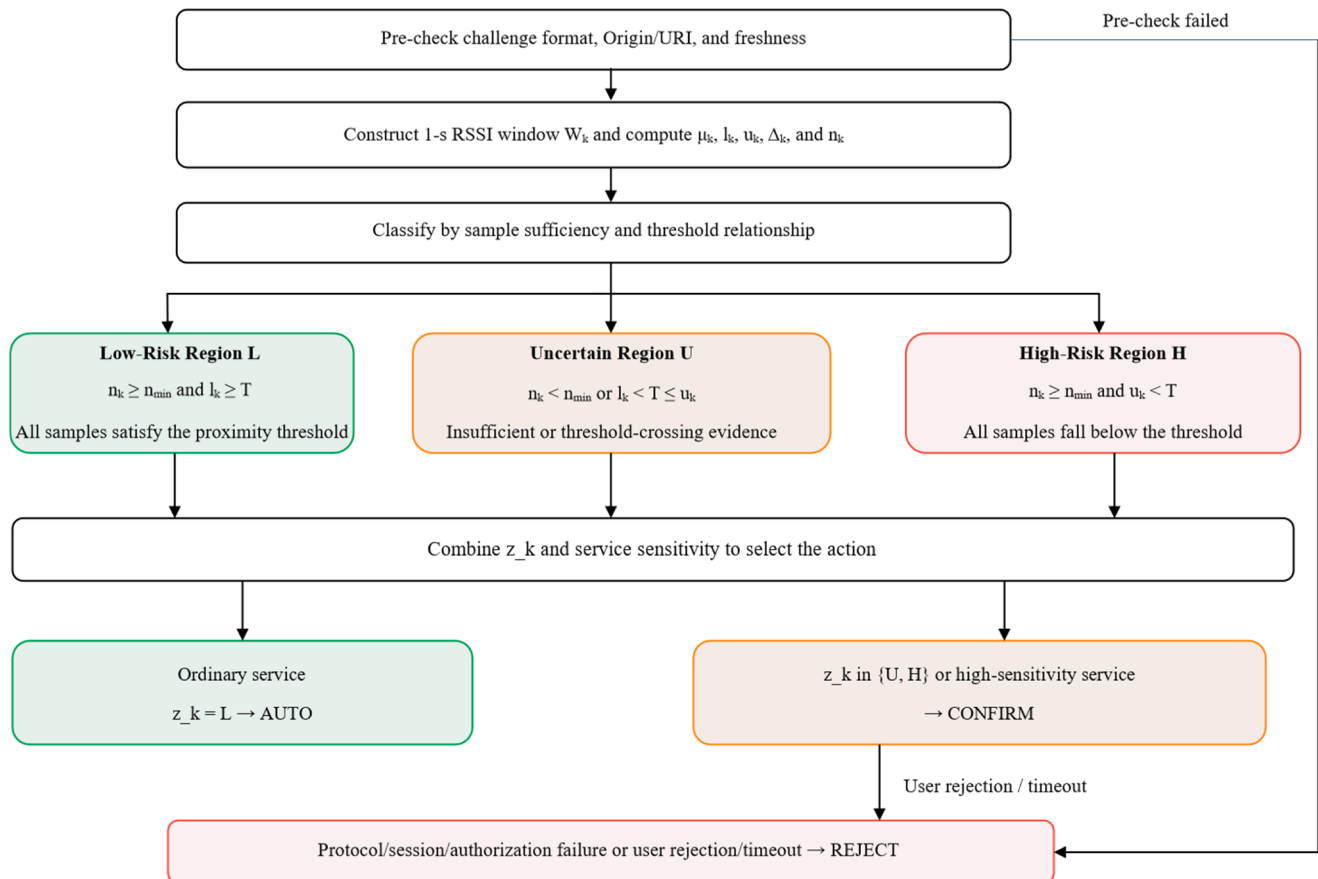


Figure 4. BLE proximity-risk decision process.

The mean μ_k describes the central signal level for trend analysis. The final risk decision uses the lower bound l_k , upper bound u_k , and sample count n_k so that a mean value cannot hide a threshold-crossing fluctuation. Let W_k be the RSSI sample set in the k -th 1 s window. The algorithm explicitly checks whether n_k reaches the minimum sample count $n_{\min}$ and computes the mean, lower bound, upper bound, and range:

$$W_k = \{r_{k,1}, \dots, r_{k,n_k}\} \quad (10)$$

$$\mu_k = \frac{1}{n_k} \sum_{i=1}^{n_k} r_{k,i} \quad (11)$$

$$l_k = \min(W_k), u_k = \max(W_k), \Delta_k = u_k - l_k \quad (12)$$

Given a deployment threshold T , the window is classified as low-risk L when $n_k \geq n_{\min}$ and $l_k \geq T$; even the weakest sample is then no lower than the threshold, so all observations consistently support proximity. The window is classified as high-risk H when $n_k \geq n_{\min}$ and $u_k < T$; even the strongest sample is below the threshold. A threshold-crossing window $l_k < T \leq u_k$ or an insufficient sample count $n_k < n_{\min}$ is classified as uncertain U . This rule represents evidence consistency and decision certainty rather than a claim that physical-signal variance changes monotonically with distance. Across all one-second windows

from both laptops, more than 99% contained at least two valid RSSI samples, and around 90% contained at least three. Accordingly, the prototype uses $n_{\min} = 2$ as the minimum multi-observation requirement, preventing a single observation from enabling AUTO while allowing as many windows as possible to remain eligible for subsequent AUTO evaluation.

AUTO (confirmation-free path). Only when the service is ordinary, the sample count is sufficient, and $z_k = L$ may the mobile application omit user confirmation and proceed to signing. The server still performs the complete cryptographic and session checks.

CONFIRM (explicit confirmation). If $z_k = U$ or H or the service is highly sensitive, the mobile application displays the Origin, service name, URI, risk region, and time and waits for the user to confirm after local unlock or verification. RSSI then only explains why the confirmation-free path is unavailable; it is not an acceptance condition after explicit confirmation.

REJECT. Invalid challenge format, Origin/URI policy, session state, or signing context, as well as user rejection or confirmation timeout, terminates the procedure without generating a signature. High-risk RSSI alone is not an identity failure; it removes eligibility for AUTO and redirects the process to CONFIRM.

The gating policy provides monotonic fallback. With other conditions unchanged, fewer samples, a transition from L to U/H , or higher service sensitivity can only change AUTO to CONFIRM. Protocol, session, or authorization failures, as well as user rejection or confirmation timeout, enter REJECT; a weaker condition cannot be upgraded in the reverse direction. With $n_{\min} = 2$, $T = -52$ dBm was selected as the lowest examined integer threshold at which no 100 cm window from either laptop entered the low-risk region, while more than 80% of the 50 cm windows remained low risk on both laptops; these settings are prototype-specific rather than universal constants.

5. Security Analysis

5.1. Basic Protocol Security

Property 1 (credential possession proof and resistance to binding replacement). Assume that the pre-binding account verification is not bypassed, SM2 signatures are unforgeable, the mobile private key is not disclosed, and the server binding nonce N_B is unpredictable and one-time. An attacker that does not possess the private key of the candidate certificate cannot bind that certificate to the victim account. Binding signature σ_B covers Tag, Origin, AccountID, CertID, N_B , and $t_{\text{exp},B}$; replacing any field causes signature verification to fail. A previous binding response is rejected because N_B has been consumed or because its binding context no longer matches. This property proves credential possession and binding-use restriction and does not depend on RSSI.

Property 2 (authentication-transcript and session-use consistency). Suppose the mobile application and server sign and verify the same deterministic DER encoding $T_A = \text{Encode}(\text{Tag}, C, H(E_k), \text{Action}_k)$, and C includes RND, SessionID, Origin, URI, CertID, expiration time, and extension fields. The resulting response is valid only within the same protocol domain, origin, service path, certificate, and Web session. Reusing it with another Tag, Origin, URI, CertID, or SessionID changes the C and T_A reconstructed from protected server state and, therefore, fails signature verification. This property does not hold if an implementation omits critical fields, permits multiple encodings for the same semantics, or trusts browser-returned session context.

Property 3 (at-most-once acceptance). Assume SessionID is unique, the server-side state record is reliable, and verification plus the ISSUED→USED transition occurs in one transaction or an equivalent atomic compare-and-swap. Even if the same authentication response is copied and submitted concurrently, it can establish at most one Web login session. Only one verification thread can successfully perform the ISSUED→USED transition;

other threads observe USED or EXPIRED, or fail the compare-and-swap, and must reject the response. Merely writing a used flag asynchronously after signature verification does not provide this property.

5.2. Session-Bound Proximity Evidence and Conditional Security Gain

Property 4 (session-bound proximity evidence). If the SM2 signature is unforgeable, H is second-preimage resistant, and the mobile application signs a transcript that fully covers C , $H(E_k)$, and $Action_k$, an attacker cannot replace low-risk evidence or an AUTO action from one session into another SessionID, Origin, URI, or observation window. Replacing E_k changes its digest, while replacing C or $Action_k$ changes the signed transcript; server verification, therefore, fails. This property protects evidence integrity and use restriction but does not establish that the RSSI reported by the trusted mobile application is absolutely truthful.

In the absence of dedicated relays or transmit-power manipulation, and assuming that greater separation or obstruction generally produces lower RSSI in the target deployment, the three-region gate excludes threshold-crossing windows, high-risk windows, insufficient samples, and unavailable reverse-RSSI paths from AUTO and routes them to CONFIRM. Once in CONFIRM, explicit user authorization replaces RSSI as the basis for $ActionAuth_{OK}$; high-risk RSSI alone does not cause authentication failure. The mechanism, therefore, reduces the opportunity for unintended use of the confirmation-free path within the stated threat model rather than providing a deterministic proof of operator identity or physical distance.

5.3. Monotonic Security Fallback

Property 5 (monotonic degradation of confirmation-free-path eligibility). The ordering $REJECT < CONFIRM < AUTO$ represents confirmation-free-path eligibility and interaction convenience, not the authorization level after a successful login. Let e denote the decision condition formed by sample sufficiency, window bounds, and service sensitivity. If e_a is no stronger than e_b —for example, because the sample count becomes insufficient, l_k falls below the threshold so L changes to U or H , or service sensitivity increases—the policy π should satisfy:

$$e_a \leq e_b \Rightarrow \pi(e_a)\pi(e_b) \quad (13)$$

The proposed rule triggers AUTO only when the service is ordinary, samples are sufficient, and $l_k \geq T$. Any weakening of a condition for the confirmation-free path causes fallback to CONFIRM; protocol/session failures, user rejection, or timeout cause REJECT. Consequently, weaker evidence cannot obtain confirmation-free-path eligibility.

5.4. Relay and Related Proximity-Manipulation Attacks

As stated in Section 3.2, relay and related proximity-manipulation attacks attempt to make a distant mobile terminal appear sufficiently close to the shared device for AUTO. Some practical attack paths require capabilities beyond ordinary access to authorized Web services, such as installing relay software or changing Bluetooth and transmit-power settings on the shared device, or placing additional radio equipment or a directional antenna near it. Other paths can instead use external relay equipment or a cooperating device near the mobile terminal and do not require software installation on the shared device. In the intended managed shared-device scenarios, device-management policies restrict the former paths, while routine physical supervision reduces the opportunity to deploy conspicuous additional equipment near the shared device without detection. These assumptions, therefore, limit some ways of implementing such attacks, although their effectiveness depends on the actual deployment.

For deployments requiring stronger resistance to relay, signal-manipulation, or device-spoofing attacks, complementary mechanisms can be selected according to the attack path. Authenticated and encrypted GATT access for bonded devices can restrict unauthorized BLE endpoints [44], while acoustic co-presence verification [47], distance-bounding protocols [48], and Bluetooth Channel Sounding [49] can provide environmental or ranging evidence that is less dependent on RSSI amplitude. Prior BLE and physical-layer relay studies [45,46] show the need for such independent evidence. This evidence can be covered by the mobile terminal's session signature and verified together with the current Origin, URI, and SessionID; if it is unavailable or inconsistent with RSSI, the system falls back to explicit confirmation.

Taken together, the deployment assumptions in Section 3.2 reduce the feasibility of preparing relay and related proximity-manipulation attacks at the shared device, while acoustic co-presence verification, distance bounding, and Bluetooth Channel Sounding provide established ways to strengthen protection when the deployment requires a more capable attacker model. These mechanisms can be selected according to the required assurance and bound to the signed authentication session as additional evidence. Because the contribution of this work is the certificate-bound authentication protocol and its RSSI-based confirmation policy, rather than a dedicated radio-relay defense, such attacks are outside the present scope.

6. Prototype Implementation and Experimental Evaluation

6.1. Prototype and Experimental Environment

To evaluate feasibility under current terminal and browser constraints, we implemented a prototype consisting of an Android authentication application, a JavaScript browser component, and a Spring Boot service. The JavaScript component is delivered with the service Web page, and no dedicated client software or browser plug-in is installed on the shared laptops. The prototype uses SM2 for digital signatures. The browser acts as a Central/GATT Client connected to the mobile GATT Server; the Android application acquires the peer shared-device RSSI through the reverse GATT path described above; the browser relays messages; and the server performs signature verification and returns the authentication and risk results for display by the browser. The implementation additionally maps Ek and Actionk to the extension fields of GB/T 40018-2021 and supports atomic SessionID consumption through a database transaction or cache compare-and-swap, depending on the deployment. This mapping demonstrates an integration path with a Chinese cryptographic deployment and does not make SM2 a prerequisite of the method. The prototype evaluation does not include an independent concurrency stress test of the SessionID-consumption mechanism.

The evaluation addresses three research questions: RQ1, whether the collected RSSI data exhibit a trend suitable for coarse proximity-risk stratification; RQ2, whether the window-bound rule separates threshold-crossing and insufficient evidence from the confirmation-free path; and RQ3, what prototype authentication-processing latency is observed. Table 1 lists the experimental devices and software. The experiments used three Android mobile terminals, two Windows laptops, Google Chrome, and Microsoft Edge. No laptop-resident helper application, browser extension, or application-defined laptop GATT service was installed. Chrome and Edge were each functionally verified for browser-side Web Bluetooth message transport, and Android-side RSSI acquisition succeeded in the evaluated configurations.

Table 1. Experimental devices and software environment.

Type	Model/Software	Configuration
Shared device (laptop1)	Honor MagicBook 14	Bluetooth 5.1
Shared device (laptop2)	Dell Precision 5530	Bluetooth 5.0
Android	HUAWEI Mate 30	Bluetooth 5.1
Android	Redmi K40	Bluetooth 5.1
Android	Google Pixel 6	Bluetooth 5.2
Browser	Google Chrome	132.0.6834.160
Browser	Microsoft Edge	132.0.2957.140

6.2. RSSI Experimental Design

In an indoor open space, RSSI was measured with the mobile terminal placed 15, 50, 100, and 150 cm from the laptop screen. An additional condition placed a solid wall between the devices at a nominal separation of 100 cm. The two laptops exhibited similar RSSI trends under the same conditions; to avoid redundancy, Figures 5–7 present the results for laptop 1. The corresponding results for laptop 2 are provided in Appendix A, Figures A1–A3.

The RSSI experiment mainly addresses RQ1 and RQ2. Raw scatter observations were first used to examine the overall signal-strength trend with increasing distance and overlap among distances. One-second mean values were then used to examine separation of central signal levels. Finally, the lower and upper bounds of each one-second window were mapped directly to the three-region rule. The one-second duration is a prototype parameter and is not claimed to be universally optimal.

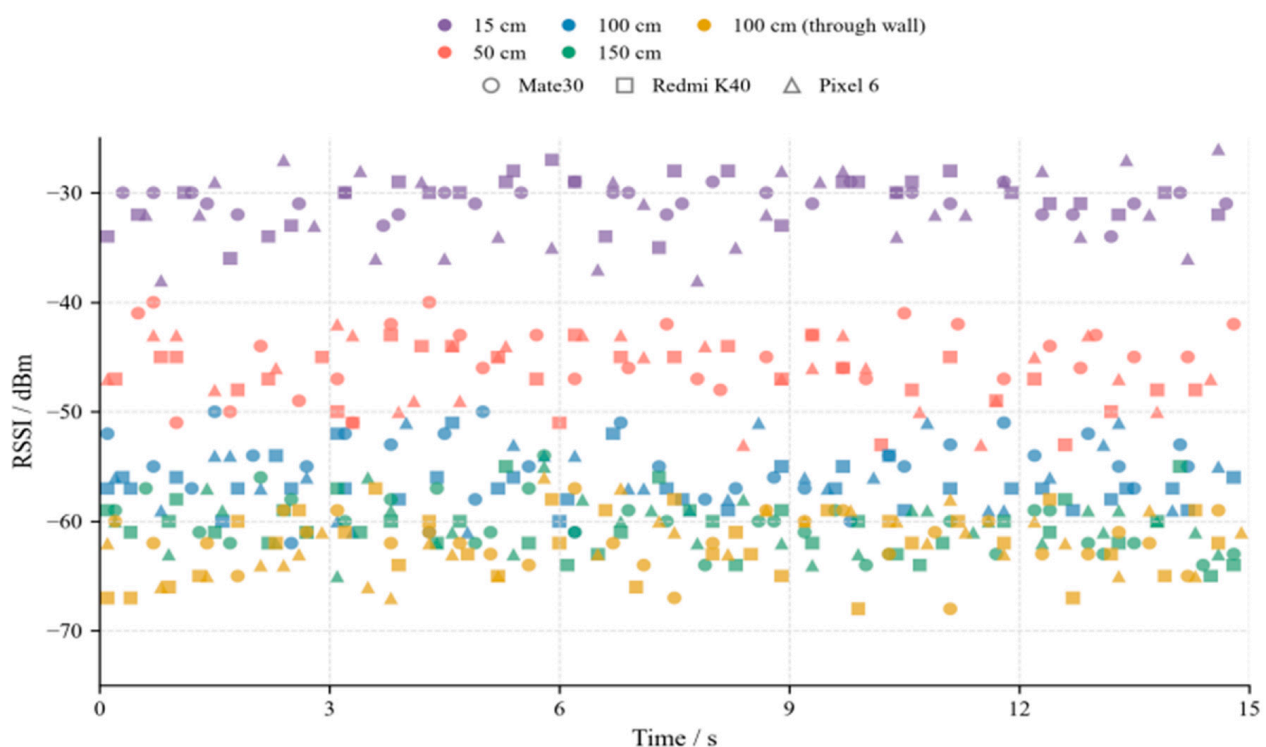
**Figure 5.** Raw RSSI at different distances for multiple devices.

Figure 5 shows the raw observations, where each point is one RSSI sample. The 15 cm condition is generally strongest, followed by 50 cm, while the 100 cm, 150 cm, and through-wall conditions are generally weaker, addressing the overall trend in RQ1. However, 50 cm and 100 cm observations overlap, and samples fluctuate substantially within the same condition. The raw data, therefore, demonstrate why a single RSSI value cannot be mapped reliably to a unique distance and is not used directly as the authentication boundary.

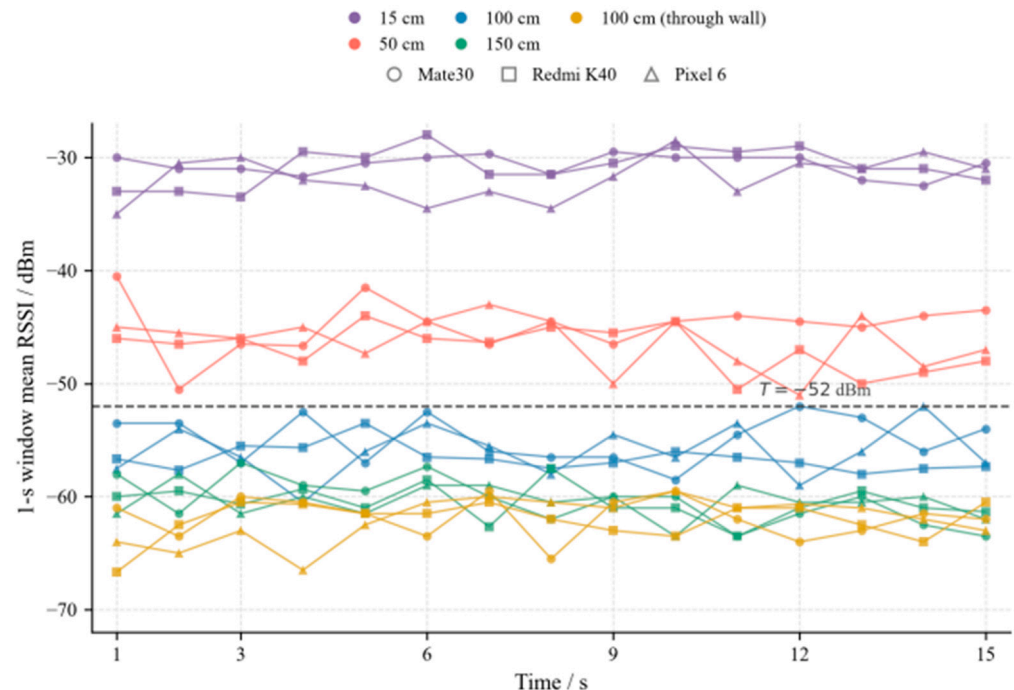


Figure 6. Mean RSSI of 1 s windows at different distances.

Figure 6 shows the distribution of one-second RSSI-window means. At the -52 dBm threshold, 100% of the mean values at both 15 cm and 50 cm reach the threshold, whereas 4.44% at 100 cm do so; the corresponding proportion is 0% at 150 cm and through the wall. The mean, therefore, captures coarse separation in central signal level but cannot reveal whether samples within one window cross the threshold. Figure 6 is, thus, not the final risk rule; it demonstrates that using only the mean loses within-window consistency information.

Figure 7a represents each one-second window as a point (l_k, u_k) , with $u_k \geq l_k$, so all valid points lie on or above the diagonal. The vertical line $l_k = T$ and horizontal line $u_k = T$ divide the feasible region into three classes. The upper-right area $l_k \geq T$ means that every sample supports low risk. The lower-left area $u_k < T$ means that every sample supports high risk. The upper-left area $l_k < T \leq u_k$ contains threshold-crossing windows. Nine single-sample windows are marked as insufficient and classified as uncertain. Unlike the raw series in Figure 5 and the mean trends in Figure 6, Figure 7a directly visualizes the final decision rule. Figure 7b shows the resulting proportions: among 45 windows per condition, 42 are low risk and 3 uncertain at 15 cm; 37 are low risk and 8 uncertain at 50 cm; 29 are high risk and 16 uncertain at 100 cm; all 45 windows are high risk at 150 cm; and 44 are high risk and 1 uncertain at 100 cm through the wall. These results answer RQ2 by showing that threshold-crossing and insufficient windows are excluded from AUTO.

Hereafter, near conditions denote 15 and 50 cm; non-near conditions denote 100 cm, 100 cm through a wall, and 150 cm. Using $T = -52$ dBm and $n_{\min} = 2$, a simple ablation compared the mean-RSSI baseline (eligible for the confirmation-free path when $n \geq n_{\min}$ and the window mean reaches T) with the three-region rule (eligible for the confirmation-free path when the window lower bound reaches T) on the same windows. For laptop

1, the three-region rule reduced the non-near confirmation-free-path eligibility rate from 1.48% to 0.00%, while the near-condition fallback-to-CONFIRM rate increased from 7.78% to 12.22%. For laptop 2, both corresponding rates were 0.00% under both rules.

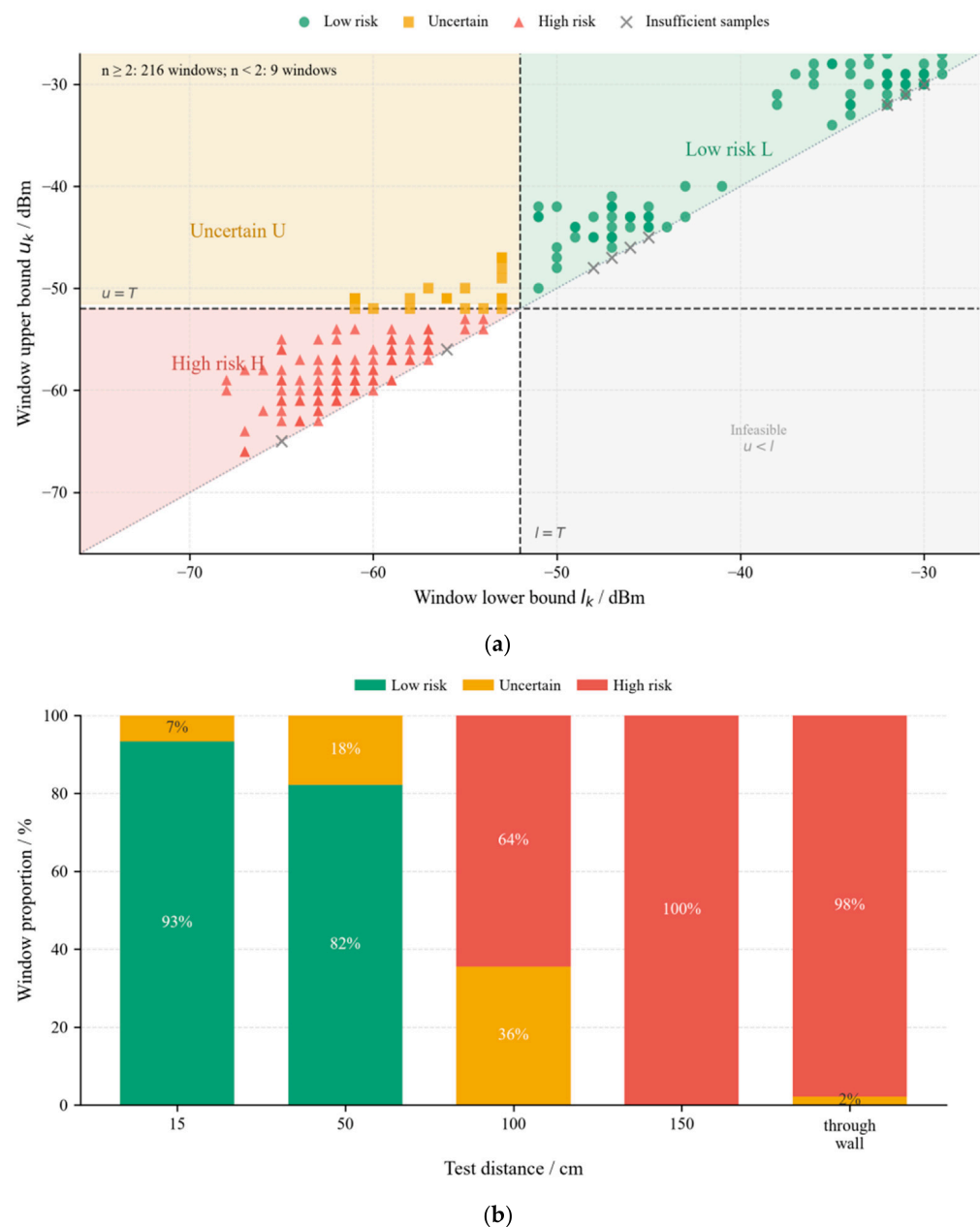


Figure 7. RSSI-window bound distribution and three-region decision results: (a) joint lower/upper-bound distribution and three-region partition; (b) three-region decision proportions at $T = -52$ dBm.

6.3. Effects of Orientation and Human-Body Disturbance

To examine the conditions most likely to approach the decision boundary, we analyzed the effects of orientation and human-body obstruction on RSSI strength using laptop 2 at 50 and 100 cm, two distances in the threshold-transition region around $T = -52$ dBm. At each distance, the three mobile terminals were evaluated with their top, right, bottom, and left edges facing the laptop. In addition, using the top-facing, unobstructed condition as the reference, we added two conditions: stationary human-body obstruction and moving-person obstruction. Each mobile-terminal-condition combination comprised one continuous record of approximately 30 s. The same prototype parameters ($T = -52$ dBm

and $n_{\min} = 2$) were used to classify the supplementary traces; these measurements extend the condition analysis but do not constitute an independent calibration/test split.

As shown in Figure 8, the condition-level mean of the one-second RSSI-window means ranged from -47.13 to -44.36 dBm at 50 cm and from -56.64 to -55.19 dBm at 100 cm. Across the four orientations, 100.00% of 50 cm windows remained in the low-risk region. At 100 cm, 84.72% of windows were classified as high risk and 15.28% as uncertain, while 0.00% entered the low-risk region. Relative to the top-facing reference, stationary human-body obstruction reduced the condition-level mean RSSI by 2.47 dB at 50 cm and 3.93 dB at 100 cm; the corresponding reductions under the moving-person condition were 1.10 and 2.57 dB. Across the stationary-body and moving-person conditions, 100.00% of 50 cm windows remained low risk. At 100 cm, 96.67% of windows were high risk and 3.33% uncertain, with 0.00% low risk. Thus, no recorded 100 cm window entered the low-risk region in these traces. This is an in-sample result for the evaluated setting, not an identity-authentication error rate or an estimate from independent attacker trials.

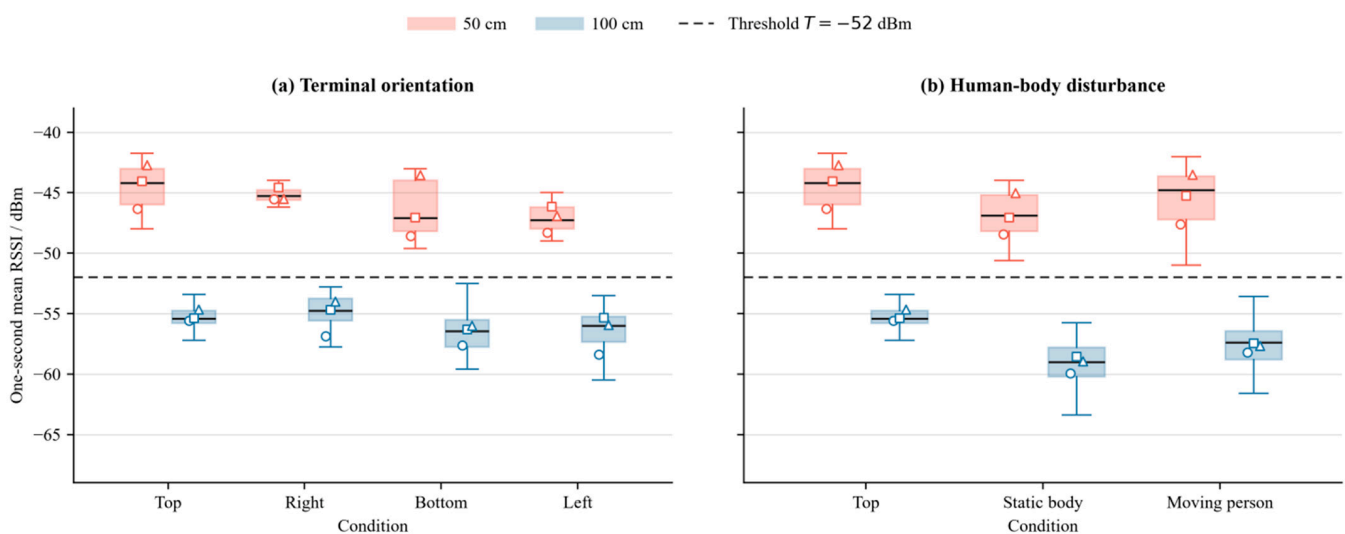


Figure 8. Effects of mobile-terminal orientation and human-body disturbance on one-second mean RSSI: (a) top, right, bottom, and left terminal edges facing the laptop; (b) top-facing reference, stationary human-body obstruction, and moving-person conditions. The dashed line indicates $T = -52$ dBm. Each aggregated condition comprises the three mobile terminals.

6.4. Authentication Processing Latency

The prototype was tested independently over 20 trials. The measured interval covered RSSI observation and gating together with authentication-protocol interaction, including BLE connection handling, signing, and server-side verification. The mean latency was 1391 ms, of which approximately 1 s was used for the RSSI observation window. Browser scanning, device-chooser display, manual device selection, and user interaction were excluded; therefore, the reported value does not represent overall or end-to-end authentication latency.

7. Discussion

The current results support three limited but explicit conclusions. First, RSSI generally decreases as distance increases, but intermediate-distance observations overlap; RSSI is, therefore, appropriate only as coarse, degradable proximity evidence rather than as a precise distance estimator, addressing RQ1. Second, the window-bound rule is not intended to make wireless measurement more accurate. Its function is to redirect insufficient and threshold-crossing evidence from AUTO to CONFIRM so that weaker evidence cannot trig-

ger confirmation-free-path eligibility, addressing RQ2. Third, the combined time for RSSI observation and gating, BLE connection handling, signing, and server-side verification averaged 1391 ms over 20 trials; browser discovery, device selection, and user interaction were excluded, so RQ3 does not measure end-to-end usability. For laptop 1, relative to the mean-RSSI baseline, the three-region rule reduced the non-near confirmation-free-path eligibility rate from 1.48% to 0.00%, while increasing the near-condition fallback-to-CONFIRM rate from 7.78% to 12.22%. The supplementary results further show that orientation and human-body disturbance change RSSI magnitude and uncertainty distribution, but no recorded 100 cm window entered the low-risk region. To avoid using identity-authentication terminology for these data, we define the non-near confirmation-free-path eligibility rate as the percentage of non-near windows in the low-risk region and the near-condition fallback-to-CONFIRM rate as the percentage of near windows outside that region. Under a distance-only adversarial proxy in which a login is initiated on the shared device while the bound mobile terminal is in a non-near condition, the non-near confirmation-free-path eligibility rate was 0.00% for both laptop 1 and laptop 2. It was also 0.00% across the supplementary 100 cm traces. These window-level, same-data outcomes characterize the interaction gate; they are not identity-authentication FAR or FRR estimates.

This study has two main limitations. First, the experiments cover only three Android terminals, two laptops, and a limited set of indoor conditions. Second, the main distance comparison uses one 15 s record per mobile-terminal-condition combination on each laptop, while the supplementary measurements use one continuous 30 s record per combination. Consecutive one-second windows from the same record are temporally related and should not be interpreted as independent trials. The experimental threshold was evaluated on the same dataset, without an independent calibration/test split. No identity-labeled legitimate/adversarial authentication trials are available. Consequently, identity-authentication FAR, FRR, and ROC curves cannot be estimated from the present dataset; the low-risk, uncertain, and high-risk proportions quantify the interaction-gating behavior of the evaluated prototype. Broader validation across additional rooms, crowded settings, and radio-interference conditions remains necessary. The Android-side reverse-RSSI path was evaluated only in the reported Windows/Chromium configurations and was not tested on macOS, Linux, non-Chromium browsers, or other Bluetooth adapters.

8. Conclusions

This study reframes terminal-assisted authentication for shared devices as a joint decision over credential verification, session binding, and risk adaptation, with the goal of reducing mobile-terminal interaction without weakening authentication security. A possession proof constrains credential registration, a canonical signed transcript restricts signature use, and a three-region RSSI-window rule determines only whether mobile confirmation may be omitted. The method requires only a verifiable signing key protected by the mobile terminal. The prototype instantiates the design with SM2 and maps proximity evidence and selected actions to extension fields of GB/T 40018-2021. Under the evaluated conditions, 93% and 82% of windows at 15 and 50 cm, respectively, were classified by the proximity gate as eligible for the confirmation-free path, whereas none at 100 cm or farther or in the through-wall condition were eligible. For laptop 1, relative to the mean-RSSI baseline, the three-region rule reduced the non-near confirmation-free-path eligibility rate from 1.48% to 0.00%, while the near-condition fallback-to-CONFIRM rate increased from 7.78% to 12.22%. The measured prototype processing time averaged 1391 ms across 20 trials, excluding browser discovery, device selection, and user interaction. These results demonstrate prototype feasibility under the evaluated configurations.

Author Contributions: L.L. was responsible for the overall scheme design and manuscript writing. W.M. was responsible for the development and implementation of the proposed method and participated in the experimental design. Q.X. was responsible for the development and implementation of the proposed method and the experimental design and supervised the overall research. G.L. participated in the experimental evaluation and manuscript revision. Z.Z. participated in the experimental evaluation and manuscript revision. All authors have read and agreed to the published version of the manuscript.

Funding: This work was supported by the Xiamen Natural Science Foundation under Grant No. 3502Z202673050; the High-Level Talent Program of Xiamen University of Technology under Grant No. YKJ25050R; the National Natural Science Foundation of China under Grant No. 62272455; and the Natural Science Foundation of Fujian Province under Grant No. 2026J0011522.

Data Availability Statement: The data presented in this study are available on request.

Acknowledgments: Declaration of Generative AI and AI-Assisted Technologies in the Manuscript Preparation Process: ChatGPT (GPT-5.6, OpenAI, San Francisco, CA, USA) was used to assist with English translation and language polishing. The authors reviewed and revised all output and take full responsibility for the final manuscript.

Conflicts of Interest: The authors declare no conflicts of interest.

Abbreviations

The following abbreviations are used in this manuscript:

Abbreviation	Definition
BLE	Bluetooth Low Energy
RSSI	Received Signal Strength Indicator
AUTO	Signing without per-request confirmation
CONFIRM	Explicit-confirmation action
REJECT	Authentication rejection action
GATT	Generic Attribute Profile
RND	Random value
SID	Session identifier (SessionID)
CTAP	Client to Authenticator Protocol
OTP	One-Time Password
DER	Distinguished Encoding Rules

Appendix A. Supplementary RSSI Results for Laptop 2

Figures A1–A3 repeat the raw-sample, one-second-mean, and window-bound analyses of Figures 5–7 for laptop 2.

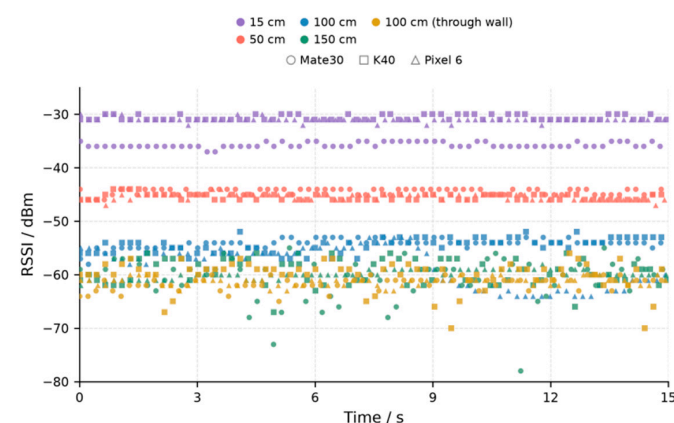


Figure A1. Raw RSSI at different distances for Laptop 2.

Figure A1 shows that laptop 2 follows the same coarse ordering observed for laptop 1: the 15 cm and 50 cm conditions are stronger overall, while the 100 cm, 150 cm, and through-wall conditions are weaker, with overlap and within-condition variation.

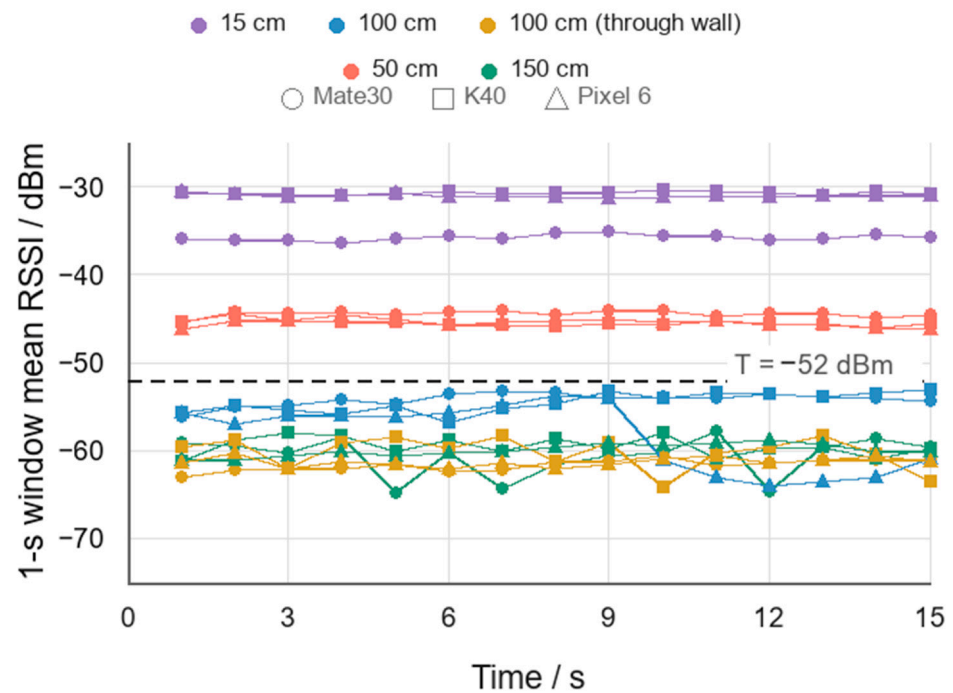
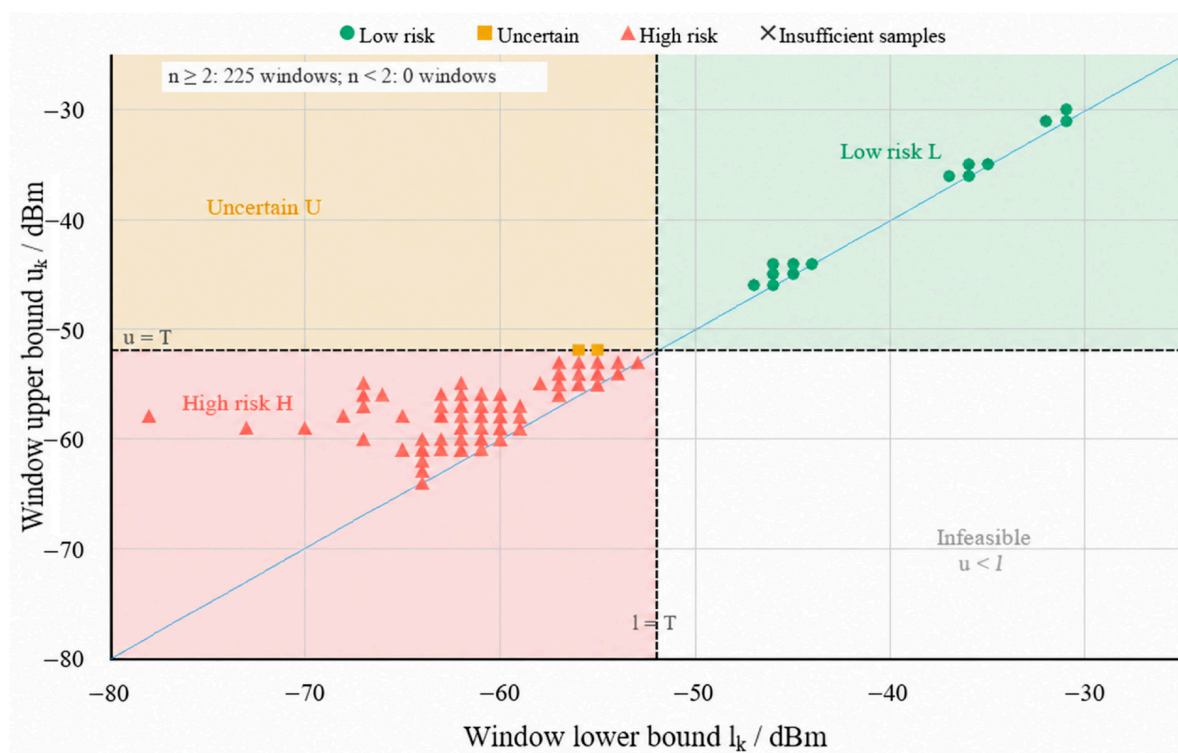


Figure A2. Mean RSSI of 1 s windows at different distances for Laptop 2.

At $T = -52$ dBm, 100% of the window means at both 15 cm and 50 cm reach the threshold, whereas 0% of the window means at 100 cm, 150 cm, and through the wall reach it.



(a)

Figure A3. Cont.

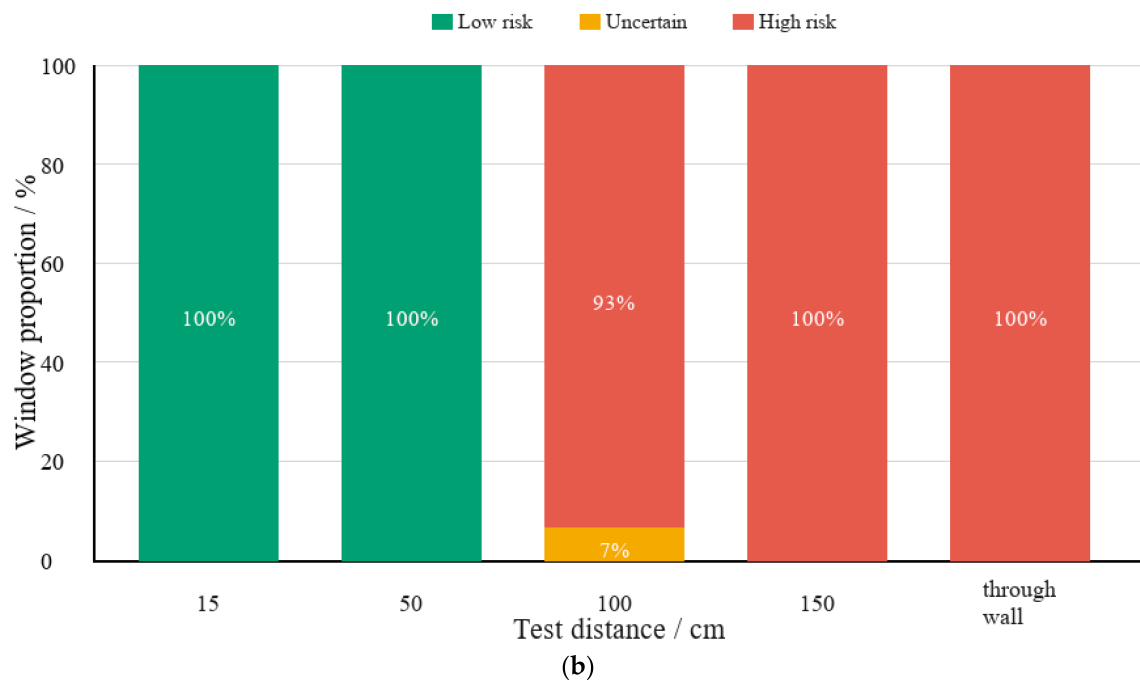


Figure A3. RSSI-window bound distribution and three-region decision results for Laptop 2: (a) joint lower/upper-bound distribution and three-region partition; (b) three-region decision proportions at $T = -52$ dBm.

Figure A3 shows a low-risk proportion of 100% at both 15 cm and 50 cm. At 100 cm, 93% of windows are high risk and 7% are uncertain; at 150 cm and through the wall, the high-risk proportion is 100%.

References

1. Ezugwu, A.; Ukwandu, E.; Ugwu, C.; Ezema, M.; Olebara, C.; Ndunagu, J.; Ofusori, L.; Ome, U. Password-based authentication and the experiences of end users. *Sci. Afr.* **2023**, *21*, e01743. [CrossRef]
2. NIST SP 800-63B-4; Digital Identity Guidelines: Authentication and Authenticator Management. National Institute of Standards and Technology: Gaithersburg, MD, USA, 2025. Available online: <https://pages.nist.gov/800-63-4/sp800-63b.html> (accessed on 30 July 2026).
3. W3C. Web Authentication: An API for Accessing Public Key Credentials—Level 3. Available online: <https://www.w3.org/TR/webauthn-3/> (accessed on 30 July 2026).
4. Apple Inc. Passkeys: Simpler and Safer Sign-In without Passwords. Available online: <https://developer.apple.com/passkeys/> (accessed on 30 July 2026).
5. Google Developers. Passkeys Overview. Available online: <https://developers.google.com/identity/passkeys> (accessed on 30 July 2026).
6. FIDO Alliance. Client to Authenticator Protocol (CTAP), Version 2.2 Proposed Standard. Available online: <https://fidoalliance.org/specs/fido-v2.2-ps-20250714/fido-client-to-authenticator-protocol-v2.2-ps-20250714.html> (accessed on 1 August 2026).
7. Karim, N.A.; Khashan, O.A.; Kanaker, H.; Abdulraheem, W.K.; Alshinwan, M.; Al-Banna, A.-K. Online banking user authentication methods: A systematic literature review. *IEEE Access* **2024**, *12*, 741–757. [CrossRef]
8. Liu, S. Optimization strategy analysis of one-click login using the local mobile number in WiFi environments. *Commun. Inf. Technol.* **2022**, *S2*, 92–96. (In Chinese)
9. Kumbhare, K.K.; Warkar, K. A review on noisy password, voiceprint biometric and one-time password. *Procedia Comput. Sci.* **2016**, *78*, 382–386. [CrossRef]
10. Aparicio, A.; Martínez-González, M.M.; Cardenoso-Payo, V. App-based detection of vulnerable implementations of OTP SMS APIs in the banking sector. *Wirel. Netw.* **2024**, *30*, 6451–6464. [CrossRef]
11. GB/T 40018-2021; Information Security Technology—Certificate Request and Application Protocol Based on Multiple Channels. Standards Press of China: Beijing, China, 2021. (In Chinese)

12. Sharevski, F.; Mossano, M.; Veit, M.F.; Schiefer, G.; Volkamer, M. Exploring phishing threats through QR codes in naturalistic settings. In Proceedings of the Symposium on Usable Security and Privacy 2024, San Diego, CA, USA, 26 February 2024; pp. 1–17. [\[CrossRef\]](#)
13. Progonov, D.; Cherniakova, V.; Kolesnichenko, P.; Oliynyk, A. Behavior-based user authentication on mobile devices in various usage contexts. *EURASIP J. Inf. Secur.* **2022**, *2022*, 6. [\[CrossRef\]](#)
14. Milton, L.C.; Memon, A. Intruder detector: A continuous authentication tool to model user behavior. In *Proceedings of the 2016 IEEE Conference on Intelligence and Security Informatics*; IEEE: Piscataway, NJ, USA, 2016; pp. 286–291. [\[CrossRef\]](#)
15. Liang, Y.; Wan, Z.; Chen, Y.; Zhao, Z.; Liu, G.; Liu, Z.; Sun, H.; Liu, Y. Vehicle-side lightweight conditional anonymous double authentication framework with password robustness in VANETs. *IEEE Trans. Dependable Secur. Comput.* **2026**, *23*, 10476–10493. [\[CrossRef\]](#)
16. Liang, Y.; Chen, J.; Bu, L.; Liu, T.; Wang, X.; Wang, B.; Zhang, G.; Sun, H. Fully decentralized authentication and key exchange scheme for data sharing in AIoMT. *IEEE Trans. Ind. Inform.* **2026**, *22*, 7136–7147. [\[CrossRef\]](#)
17. Liang, Y.; Sun, H.; Zhang, X.; Xie, Q.; Liu, G.; Liu, Z.; Tan, Z.; Liu, Y. Lightweight multifactor authentication and key agreement scheme in vehicle-to-grid networks. *IEEE Trans. Veh. Technol.* **2026**, *75*, 6582–6599. [\[CrossRef\]](#)
18. Liang, Y.; Liu, G.; Zhang, X.; Chen, Y.; Chen, J.; Xia, Y.; Liu, Y. Fully anonymous broadcast signcryption for secure health data transmission in WBANs. *IEEE Trans. Mob. Comput.* **2026**, *25*, 1729–1743. [\[CrossRef\]](#)
19. Corner, M.D.; Noble, B.D. Zero-interaction authentication. In *Proceedings of the 8th Annual International Conference on Mobile Computing and Networking*; ACM: New York, NY, USA, 2002; pp. 1–11. [\[CrossRef\]](#)
20. Jansen, W.; Gavrilu, S.I.; Korolev, V. Proximity-based authentication for mobile devices. In Proceedings of the 2005 International Conference on Security and Management, Las Vegas, NV, USA, 20–23 June 2005. Available online: <https://www.nist.gov/publications/proximity-based-authentication-mobile-devices> (accessed on 1 August 2026).
21. Varshavsky, A.; Scannell, A.; LaMarca, A.; de Lara, E. Amigo: Proximity-based authentication of mobile devices. In *UbiComp 2007: Ubiquitous Computing*; Springer: Berlin/Heidelberg, Germany, 2007; pp. 253–270. [\[CrossRef\]](#)
22. Mathur, S.; Miller, R.; Varshavsky, A.; Trappe, W.; Mandayam, N. ProxiMate: Proximity-based secure pairing using ambient wireless signals. In *Proceedings of the 9th International Conference on Mobile Systems, Applications, and Services*; ACM: New York, NY, USA, 2011; pp. 211–224. [\[CrossRef\]](#)
23. Karapanos, N.; Marforio, C.; Soriente, C.; Čapkun, S. Sound-Proof: Usable two-factor authentication based on ambient sound. In *Proceedings of the 24th USENIX Security Symposium*; USENIX Association: Berkeley, CA, USA, 2015; pp. 483–498. Available online: <https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/karapanos> (accessed on 12 September 2026).
24. Truong, H.T.T.; Gao, X.; Shrestha, B.; Saxena, N.; Asokan, N.; Nurmi, P. Comparing and fusing different sensor modalities for relay attack resistance in zero-interaction authentication. In *Proceedings of the 2014 IEEE International Conference on Pervasive Computing and Communications*; IEEE: Piscataway, NJ, USA, 2014; pp. 163–171. [\[CrossRef\]](#)
25. Shrestha, B.; Shirvanian, M.; Shrestha, P.; Saxena, N. The sounds of the phones: Dangers of zero-effort second factor login based on ambient audio. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*; ACM: New York, NY, USA, 2016; pp. 908–919. [\[CrossRef\]](#)
26. Ramirez, R.; Huang, C.Y.; Liao, C.A.; Lin, P.T.; Lin, H.W.; Liang, S.H. A practice of BLE RSSI measurement for indoor positioning. *Sensors* **2021**, *21*, 5181. [\[CrossRef\]](#) [\[PubMed\]](#)
27. Fluoratoru, L.; Shubina, V.; Niculescu, D.; Lohan, E.S. On the high fluctuations of received signal strength measurements with BLE signals for contact tracing and proximity detection. *IEEE Sens. J.* **2022**, *22*, 5086–5100. [\[CrossRef\]](#)
28. Filus, K.; Nowak, S.; Domańska, J.; Duda, J. Cost-effective filtering of unreliable proximity detection results based on BLE RSSI and IMU readings using smartphones. *Sci. Rep.* **2022**, *12*, 2440. [\[CrossRef\]](#) [\[PubMed\]](#)
29. Bluetooth SIG. Bluetooth Core Specification (Amended) 5.1. Available online: <https://www.bluetooth.com/specifications/specs/core-specification-amended-5-1/> (accessed on 4 August 2026).
30. Pau, G.; Arena, F.; Gebremariam, Y.E.; You, I. Bluetooth 5.1: An analysis of direction finding capability for high-precision location services. *Sensors* **2021**, *21*, 3589. [\[CrossRef\]](#) [\[PubMed\]](#)
31. Alawami, M.A.; Kim, H. LocAuth: A fine-grained indoor location-based authentication system using wireless networks characteristics. *Comput. Secur.* **2020**, *89*, 101683. [\[CrossRef\]](#)
32. Mussina, A.; Aubakirov, S. RSSI-based Bluetooth Low Energy indoor positioning. In *Proceedings of the 2018 IEEE 12th International Conference on Application of Information and Communication Technologies*; IEEE: Piscataway, NJ, USA, 2018; pp. 1–4. [\[CrossRef\]](#)
33. Li, G.; Geng, E.; Ye, Z.; Xu, Y.; Zhu, H. An indoor positioning algorithm based on RSSI real-time correction. In *Proceedings of the 2018 14th IEEE International Conference on Signal Processing*; IEEE: Piscataway, NJ, USA, 2018; pp. 129–133. [\[CrossRef\]](#)
34. Türkorall, T.; Tamer, Ö.; Yetiş, S.; İnanç, E.; Çetin, L. Short range indoor distance estimation by using RSSI metric. *Istanbul Univ.-J. Electr. Electron. Eng.* **2017**, *17*, 3295–3302.

35. Wang, Y.; Yang, X.; Zhao, Y.; Liu, Y.; Cuthbert, L. Bluetooth positioning using RSSI and triangulation methods. In *Proceedings of the 2013 IEEE 10th Consumer Communications and Networking Conference*; IEEE: Piscataway, NJ, USA, 2013; pp. 837–842. [\[CrossRef\]](#)
36. Ma, Z.; Poslad, S.; Bigham, J.; Zhang, X.; Men, L. A BLE RSSI ranking based indoor positioning system for generic smartphones. In *Proceedings of the 2017 Wireless Telecommunications Symposium*; IEEE: Piscataway, NJ, USA, 2017; pp. 1–8. [\[CrossRef\]](#)
37. Junoh, S.A.; Pyun, J.Y. Augmentation of fingerprints for indoor BLE localization using conditional GANs. *IEEE Access* **2024**, *12*, 30176–30190. [\[CrossRef\]](#)
38. Zhang, A.; Yuan, Y.; Wu, Q.; Zhu, S.; Deng, J. Wireless localization based on RSSI fingerprint feature vector. *Int. J. Distrib. Sens. Netw.* **2015**, *11*, 528747. [\[CrossRef\]](#)
39. Huang, J.; Hu, X.; Tian, Y. A novel RSSI-based geometric iterative centroid positioning optimization strategy using commercial Wi-Fi signals. *ETRI J.* **2025**, *47*, 909–920. [\[CrossRef\]](#)
40. NHS England Digital. Smartcards That Need an HSCN Connection. Available online: <https://digital.nhs.uk/services/care-identity-service/applications-and-services/cis2-authentication/smartcards-requires-hscn> (accessed on 1 August 2026).
41. Guangzhou Municipal People's Government. Focusing on the "One-Window Integrated Service" Reform: Guangzhou Public Security Builds an Integrated Comprehensive Service Window System. Available online: https://www.gz.gov.cn/zfwf/zxfw/ggfw/content/post_9178625.html (accessed on 1 August 2026). (In Chinese)
42. Microsoft. Get Started with Windows Frontline Worker Devices. Available online: <https://learn.microsoft.com/en-us/intune/solutions/frontline-worker/windows> (accessed on 1 August 2026).
43. Web Bluetooth Community Group. Web Bluetooth: Draft Community Group Report. Available online: <https://webbluetoothcg.github.io/web-bluetooth/> (accessed on 30 July 2026).
44. Bluetooth SIG. Bluetooth Core Specification, Version 6.0, Vol. 3, Part C: Generic Access Profile, Section 10: Security Aspects—LE Physical Transport. Available online: <https://www.bluetooth.com/wp-content/uploads/Files/Specification/HTML/Core-60/out/en/host/generic-access-profile.html> (accessed on 6 September 2026).
45. Khan, S.Q.; NCC Group. Technical Advisory—BLE Proximity Authentication Vulnerable to Relay Attacks. 15 May 2022. Available online: <https://www.nccgroup.com/research/technical-advisory-ble-proximity-authentication-vulnerable-to-relay-attacks/> (accessed on 6 September 2026).
46. Staat, P.; Jansen, K.; Zenger, C.; Elders-Boll, H.; Paar, C. Analog physical-layer relay attacks with application to Bluetooth and phase-based ranging. In *Proceedings of the 15th ACM Conference on Security and Privacy in Wireless and Mobile Networks (WiSec '22)*; ACM: New York, NY, USA, 2022; pp. 60–72. [\[CrossRef\]](#)
47. Truong, H.T.T.; Toivonen, J.; Nguyen, T.D.; Soriente, C.; Tarkoma, S.; Asokan, N. DoubleEcho: Mitigating context-manipulation attacks in copresence verification. In *Proceedings of the 2019 IEEE International Conference on Pervasive Computing and Communications (PerCom)*; IEEE: Piscataway, NJ, USA, 2019; pp. 1–9. [\[CrossRef\]](#)
48. Brands, S.; Chaum, D. Distance-bounding protocols. In *Advances in Cryptology—EUROCRYPT '93; Lecture Notes in Computer Science*; Springer: Berlin/Heidelberg, Germany, 1994; Volume 765, pp. 344–359. [\[CrossRef\]](#) [\[PubMed\]](#)
49. Bluetooth SIG. Bluetooth Channel Sounding. Available online: <https://www.bluetooth.com/learn-about-bluetooth/feature-enhancements/channel-sounding/> (accessed on 6 September 2026).

Disclaimer/Publisher's Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.